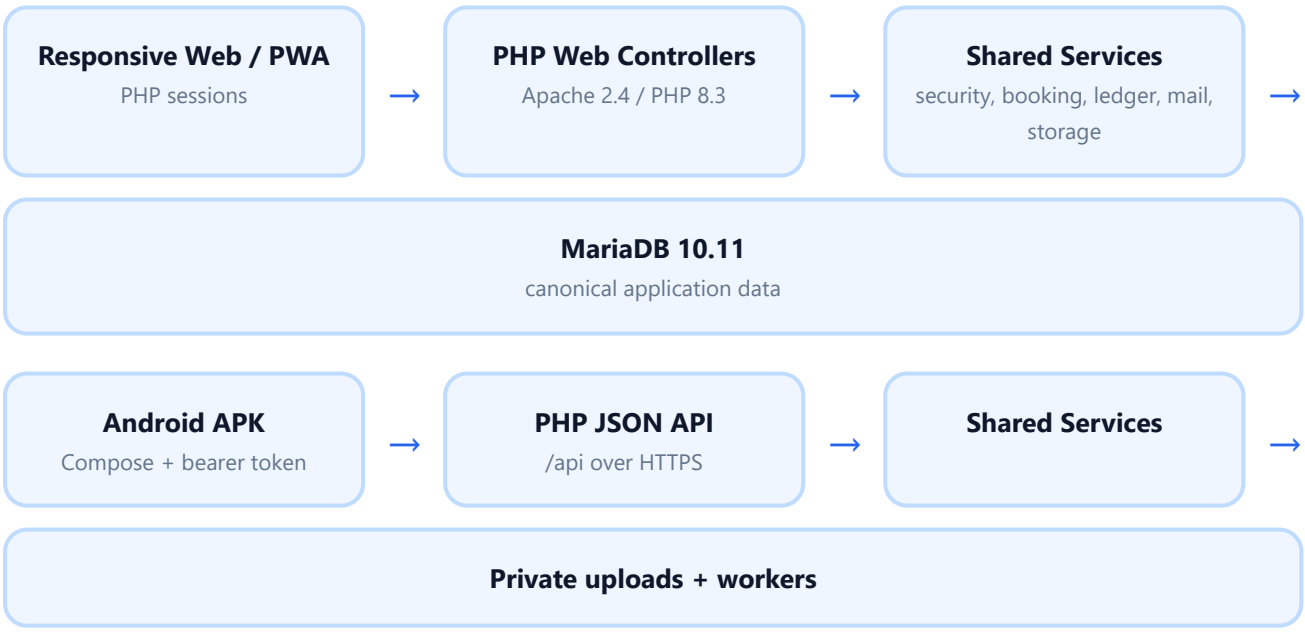
NANNY-APP · PRODUCT & ENGINEERING

Technical Requirements Document

Architecture, platform specifications and non-functional requirements

Version 1.0 10 October 2026 Status: implementation baseline + launch requirements

1. System architecture



Both interfaces use one transactional data model and storage abstraction. CLI workers deliver queued email/notifications and delete unreferenced files. The AWS pilot places Caddy, Apache/PHP, MariaDB and workers on one encrypted EC2 host.

2. Technology specifications

Layer	Technology	Requirement
Web	PHP 8.3, Apache, HTML/CSS/vanilla JS	Server-rendered responsive pages, secure sessions, no displayed production errors.
Mobile	Kotlin, Jetpack Compose, Material 3	Android 8+ (minSdk 26), targetSdk 35, Java 17 bytecode.
Mobile data	Retrofit/OkHttp, Room, DataStore, WorkManager, Hilt	HTTPS release endpoint; account-scoped cache; token revocation handling.
Database	MariaDB 10.11 / PDO	utf8mb4, InnoDB, real prepared statements, versioned migrations.
Edge	Caddy 2	TLS termination, HSTS, reverse proxy to private Apache port.
AWS pilot	EC2, Elastic IP, encrypted gp3 EBS	Stockholm eu-north-1; 80/443 public, 22 restricted, 3306 private.

3. Performance and capacity

- Target p95 authenticated page/API response under 800 ms at pilot load, excluding email delivery and large media transfer.
- Database-backed lists must paginate before any table can exceed 500 rows; message thread currently caps at 500 and should add cursor pagination before scale.
- Uploads default to 100 MiB aggregate and 20 MiB free-disk reserve; configure production values from measured EBS use.
- Workers process bounded batches (up to 100 jobs) and run every minute; alert when oldest due job exceeds five minutes.
- Measure CPU, memory, DB locks, disk, request latency and error rate before resizing or separating RDS/S3.

4. Security requirements

Identity

Bcrypt passwords, verified active accounts, 90-day bearer expiry, credential rotation, rate limiting and admin exclusion from Android.

Authorization

Role and ownership checks at every controller; parent-only PIN visibility; private media streamed or short-lived signed after authorization.

Application

CSRF for web mutations, strict JSON validation, PDO prepared statements, output escaping, safe 4xx errors and no public worker/migration endpoints.

Infrastructure

HTTPS only, HSTS, secrets outside source, IMDSv2, encrypted disks/backups, DB unexposed and restricted SSH.

5. Reliability, recovery and scalability

Area	Pilot requirement	Scale trigger
Availability	Single-host accepted failure point; external HTTPS plus internal DB/queue checks.	Add separate managed DB/application instances when outage target demands it.
Backups	Encrypted off-host DB and upload copy; documented restore drill.	Increase frequency/binlog archive if agreed data-loss window shrinks.
Storage	Persistent private EBS volume.	Move bytes to private S3 for multi-host or storage growth.
Concurrency	Row locks and transactions for bookings/ledger; outbox for durable side effects.	Add request idempotency before retry-heavy/public growth.
Rollback	Keep prior image; additive schema; never overwrite new bookings with old DB.	Automate serialized deployment after release frequency rises.

6. Quality and observability

- PHP syntax, JavaScript syntax, migration, HTTP/auth/media, security, PWA, cache-isolation and APK-download tests must pass.
- Android debug assembly, JVM tests and lint must pass; release must reject absent or non-HTTPS API URL.
- Logs exclude authorization/cookies, request bodies and account-link query strings.
- Alert on repeated 5xx, worker failures, pending queues, low disk, DB failure, TLS failure and backup failure.

> **Known delivery limit:** source checks are not production evidence. Live mail, AWS deployment, restore, signing and physical-device validation remain mandatory.

Document suite